Training & Awareness Policy

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

This policy establishes the requirements for security awareness, education, and training to ensure that all Stark Industries personnel understand their responsibilities in maintaining the confidentiality, integrity, and availability of information assets. This policy is aligned with ISO/IEC 27001:2022 (A.6.3 – A.6.5).

Scope

Applies to all Stark Industries employees, contractors, interns, and third-party users who have access to the organisation's systems, applications, or data.

Objectives

- Ensure that employees are aware of their information security responsibilities
- Provide training appropriate to roles and access levels
- Foster a security-aware culture across the organisation

Induction Training (A.6.3)

- All new hires must complete mandatory information security awareness training within **30 days** of joining.
- Induction training includes:
    - Overview of the ISMS
    - Secure use of systems and assets
    - Data protection basics
    - How to report a security incident

Ongoing Awareness (A.6.4)

- Security awareness refresher training is required **annually** for all staff.
- Quarterly awareness campaigns (email, posters, Slack messages) will reinforce best practices.
- Employees must acknowledge major policy updates electronically.

Role-Based Training (A.6.5)

- Additional, targeted training must be delivered to:
  - **Developers** – Secure coding practices, OWASP Top 10
  - **GRC/InfoSec staff** – ISO 27001, risk treatment, audit prep
  - **Privileged users** – Least privilege, system hardening, MFA
  - **Incident Responders** – IR procedures, evidence handling

Training Records and Metrics

- Completion of all mandatory training is tracked by the **GRC Analyst**
- Monthly reports are submitted to the **Information Security Manager**
- Audit logs of participation are retained for at least **3 years**

Accountability

- Failure to complete required training may result in:
  - Temporary restriction of access
  - Disciplinary action
- Managers are responsible for ensuring their team's participation

Roles and Responsibilities

Role	Responsibility
Information Security Manager	Approves training content and ensures policy compliance
GRC Analyst	Tracks completion, maintains training logs, and issues reminders
People & Culture (HR)	Ensures onboarding training is delivered on time
All Employees	Complete training as required and follow guidance

Compliance and Auditing

- Logging is auditable and aligned with:
  - ISO 27001
  - Customer SLAs and due diligence requirements
- Quarterly internal audits are conducted on:
  - Log integrity
  - Review completeness
  - Alerting thresholds

Exceptions

Any exceptions to this policy must be:

- Documented with a valid justification
- Reviewed and approved by the Information Security Manager

Policy Review

- This policy is reviewed **annually** or upon significant change to the environment or regulatory requirements.